Phishing Email Detection & Awareness System

1. Introduction

This document describes the proceedings and results of the analysis of **Sample-1012.eml** phishing email samples. This report lists the technical findings, corresponding best practices for mitigation, and mitigation recommendations.

2. Objective

The objective of this analysis was to assess the state of security, uncover common vulnerabilities used by attackers, and provide a standardized security assessment report that includes identified vulnerabilities, a remediation strategy, and prevention guidelines to help mitigate future risks..

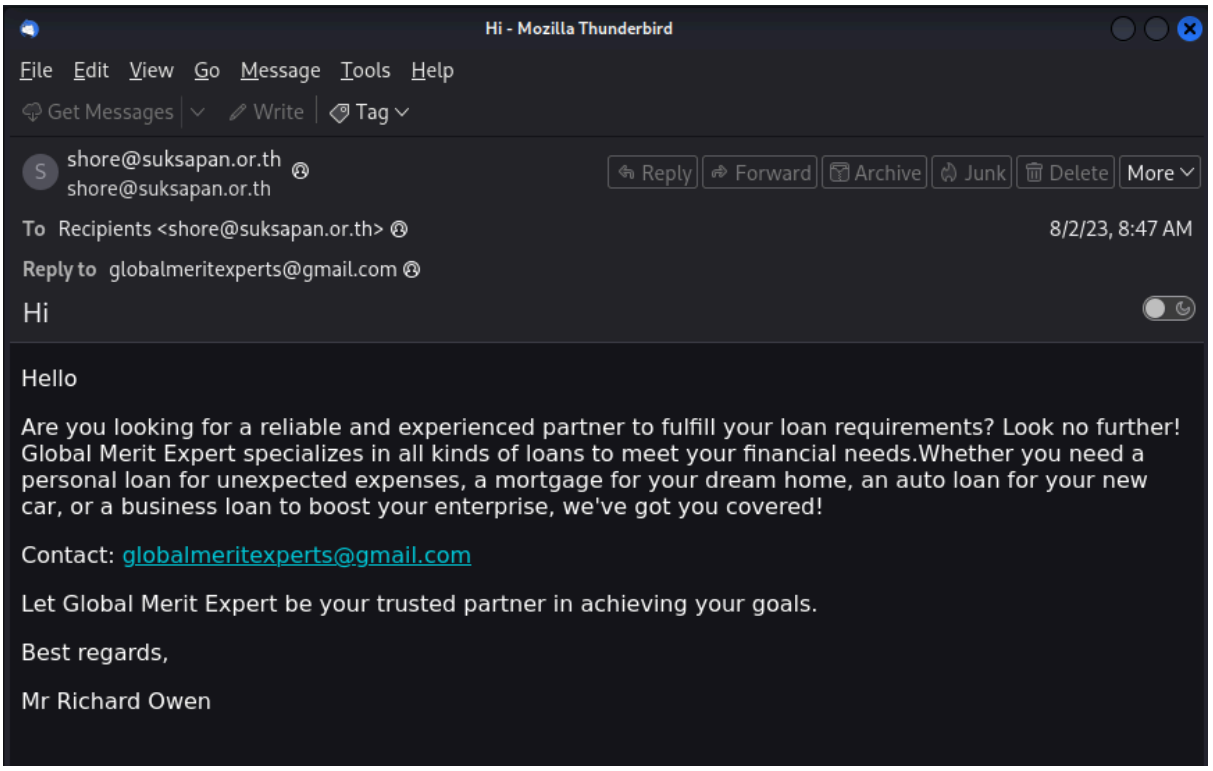
3. Scope

This analysis is defined within the scope of investigating [Insert Number] specific email artifacts (e.g., mail files, .eml files). The target company and URLs listed in the findings are fictional and used for analytical demonstration only.

Technical Analysis of Phishing Samples

Email Sample 01: Sample-1012.eml.

IMAGE 1



1. Collect phishing email samples:
    - Sample Source: https://github.com/rolandslt/FUTURE_CS_1.git.task_2/mail
    - Subject: Hi
    - To: Recipients <shore@suksapan.or.th>
    - From: shore@suksapan.or.th
    - Date: Wed, 02 Aug 2023 13:47:50 +0100
    - Name signed to the body : Mr Richard Owen
    - Mail assigned in the body : globalmeritexperts@gmail.com
    - Reply to : globalmeritexperts@gmail.com
    - Return-Path: shore@suksapan.or.th
2. Analyze email headers:
    - Authentication-Results: spf=softfail (sender IP is 202.129.206.234) smtp.mailfrom=suksapan.or.th; dkim=none (message not signed) header.d=none;dmarc=none action=none header.from=suksapan.or.th;compauth=fail reason=001

3. Inspect sender domain & links:
    - DNS of the mail server sender **suksapan.or.th** find ad IP 185.54.90.149 from AS 9287 (True Internet Data Center Company Limited) THailand
    - The sender mail is configured with a 102.69.139.1111(102.69.128.0/20) AS 328431 (Connected-Space-AS) south-africa , public IP address that sends the email to the server and helo=[192.168.88.181] → The sender identified itself using a private/local IP (not routable on the internet).
    - Primary Hostname - host4.ns.co.th, 202.129.206.234 (202.129.206.0/23)AS 132300 (NIPA TECHNOLOGY CO., LTD)THailand
    - Original Domain - hotmail.com, 204.79.197.212 (204.79.197.0/24) AS 8068 (Microsoft Corporation) US

4. Identify phishing indicators:
    - Indicator 1:

spf=softfail (sender IP is 202.129.206.234), the server is not critical insecure but has configuration weaknesses as the message is not signed ,has no DMARC , which is a show of a specious mail (IMAGE 2)

    - Indicator 2:

The sender used different domains that enveloped its mail to hide its trace considering a special mail ,he used three different domain servers ,in thailand , south africa and us ,which is a sign of an act of someone who doesn't want to look specious .

    - Indicator 3:

The Reply mail which is also the mail included in the mail boy represent a misconfiguration which needs to be strengthened ,DMARC is not enforcing a quarantine or reject policy, which weakens protection against spoofed emails and phishing attempts.
SPF and MX configurations are present but stronger enforcement is recommended to improve trust and enable advanced protections like BIMI.(IMAGE 3)

Several DNS settings (SOA values) fall outside recommended ranges, indicating minor configuration issues. SMTP checks reported banner and reverse DNS mismatches on some mail servers, which may affect email reputation.(IMAGE 4)

5. Document findings clearly:

IMAGE 2

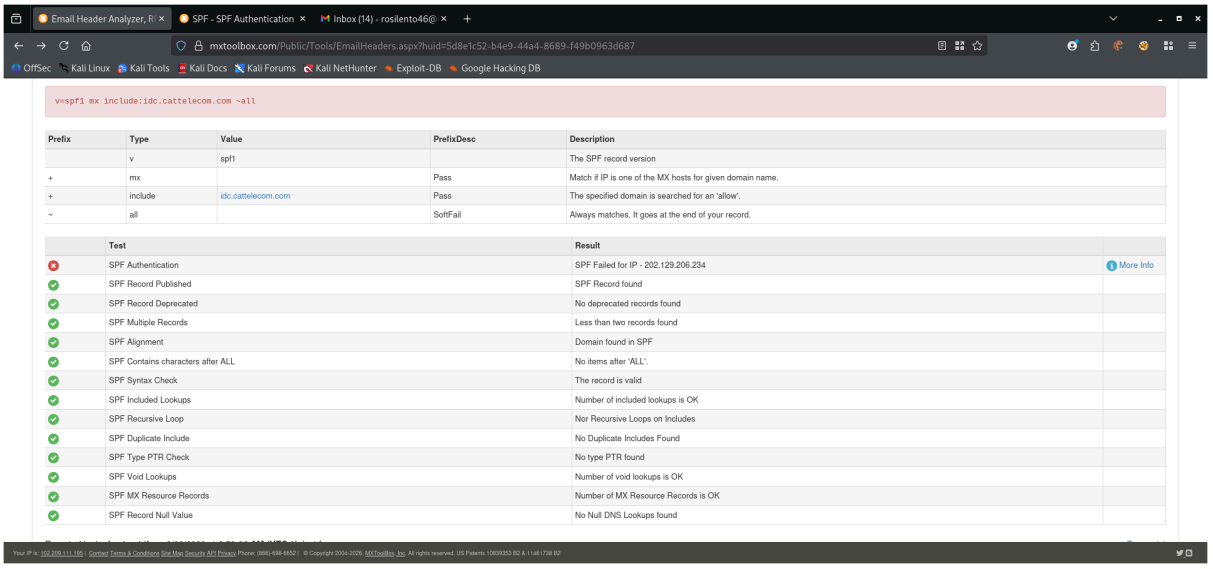


IMAGE 3

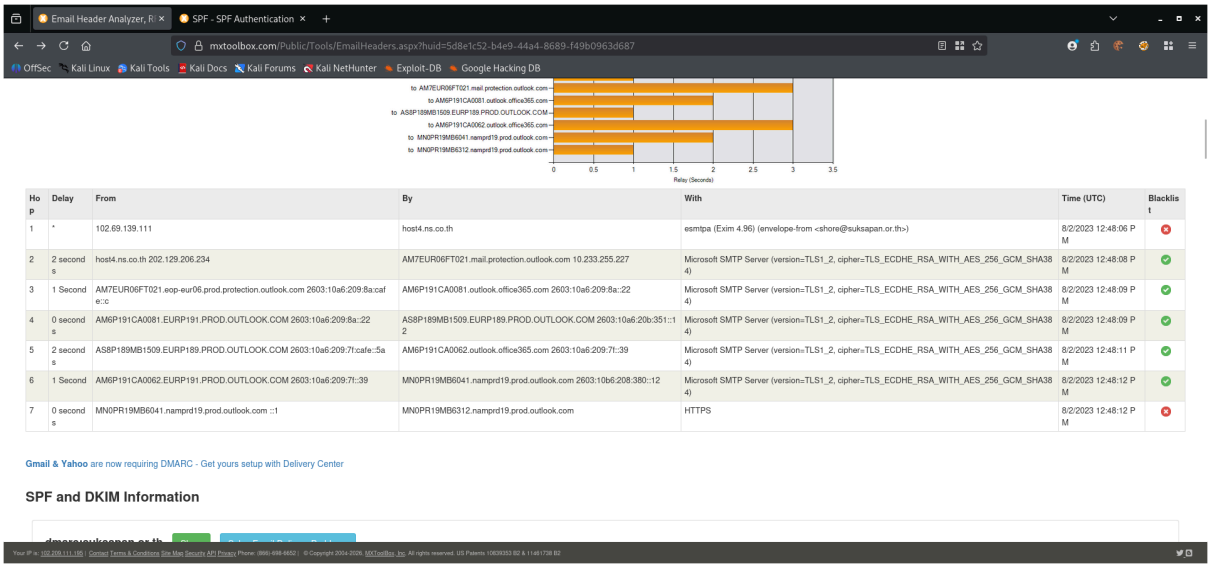
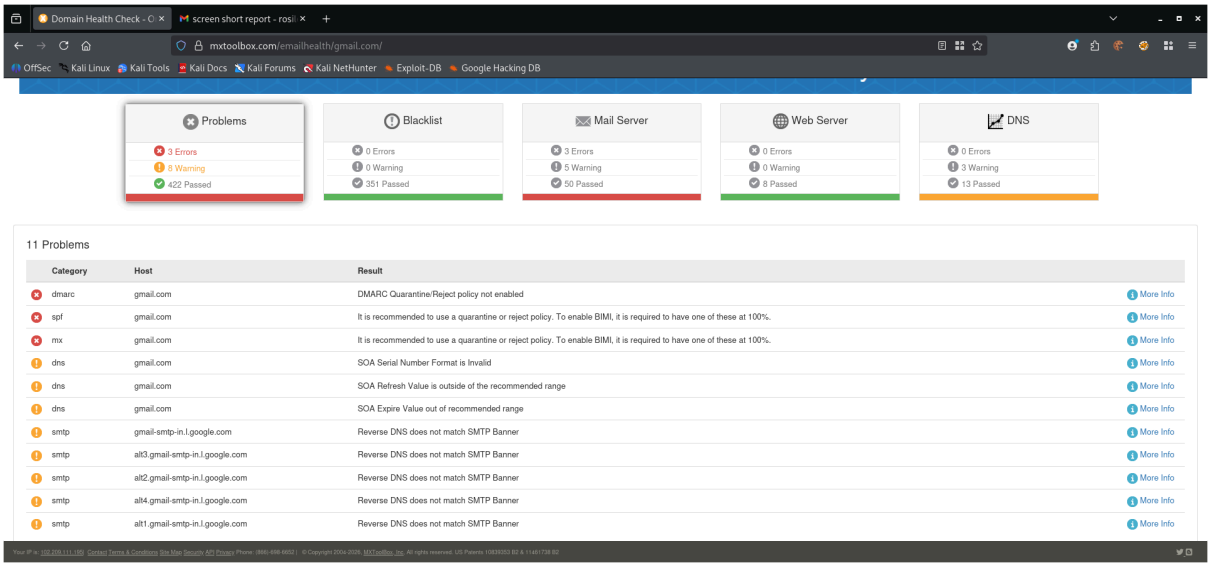


IMAGE 4



6. prevention & awareness guidelines:
    - The "Hover" Test

Before you click any link, hover your mouse over it. A small box will appear at the bottom of your screen showing the real website address. If the address looks strange or doesn't match the email, do not click it.

    - Check the "From" Address

Don't just trust the name you see (like "Bank Support"). Click on the name to see the actual email address behind it. If it’s a long string of random letters or doesn't end in the official company website (e.g., @google.com), it is a fake.

    - Use Two-Factor Authentication (2FA)

Always turn on Two-Factor Authentication (the code sent to your phone) for your accounts. Even if a hacker successfully steals your password through a fake email, they still won't be able to get into your account without that second code.

---

4. Overall Remediation Strategy & Recommendations Guidelines

Short-Term: Immediate Technical Fixes

- **Update Email Rules:** Configure the email gateway to automatically move any email that fails SPF (like the sample analyzed) directly to the Junk folder or block it entirely.
- **Enable "Reject" Mode:** Change the domain's security settings (DMARC) from "do nothing" to "Reject." This tells the internet to delete fake emails pretending to be from your company before they reach anyone's inbox.
- **Blacklist Malicious IPs:** Add the identified IP address (202.129.206.234) and the originating server (102.69.139.111) to the company’s "Block List" immediately.

Long-Term: Strengthening the "Human Firewall"

- **Mandatory Multi-Factor Authentication (MFA):** Ensure every employee uses a second code (via phone or app) to log in. This makes stolen passwords useless to hackers.
- **Monthly Simulation Drills:** Send out "safe" fake phishing emails to staff. If an employee clicks the link, they receive immediate, friendly training on what they missed.
- **Clear Reporting Path:** Make sure every employee knows exactly how to use the "Report Phishing" button. Fast reporting by one person can save the entire company from a breach.